

SECURITY TESTING REPORT

1. Overview

This document provides a detailed and structured account of all security testing performed on the Secure Healthcare Patient Portal. The objective of this report is to validate the effectiveness of implemented security controls against real-world attack scenarios. Testing was conducted with a strong focus on authentication, authorization, input validation, and Web Application Firewall (WAF) behavior.

2. Testing Methodology

Testing followed a combination of manual and practical approaches aligned with OWASP Testing Guide principles.

- Static Analysis (manual code review)
- Dynamic Application Testing (live API interaction)
- Authentication & Session Testing
- Authorization & IDOR Testing
- Input Validation Testing
- WAF Injection Testing (OWASP Top 10)
- Security Header Verification

3. Authentication & Session Testing

A total of 10 test cases were executed to evaluate authentication robustness, session handling, and MFA enforcement.

- Invalid JWT signature — Token tampering attempt → PASS
- Expired JWT — Replay with expired token → PASS
- Missing Authorization header → PASS
- Unapproved doctor login attempt → PASS
- Deactivated account login → PASS
- Invalid MFA code submission → PASS
- Brute-force login attempt (rate limiting) → PASS
- Account enumeration via forgot-password → PASS

-

- Weak password policy enforcement → PASS

MFA bypass using AAL1 token → PASS

4. Authorization & IDOR Testing

8 test cases were executed to verify role-based access control and protection against IDOR attacks.

- Patient accessing doctor endpoints → PASS

- Patient accessing another patient's data → PASS

- Doctor accessing unassigned patient → PASS

- Patient accessing admin endpoints → PASS

- WAF admin endpoint without API key → PASS

- Forced browsing (.env exposure) → BLOCKED

- Forced browsing (.git exposure) → BLOCKED

- UUID manipulation (IDOR attempt) → PASS

5. WAF Injection Testing

A total of 21 attack payloads were tested against the WAF covering major OWASP Top 10 categories.

SQL Injection

- UNION SELECT payload → BLOCKED

- Time-based injection (SLEEP) → BLOCKED

- information_schema access → BLOCKED

- sqlmap user-agent detection → BLOCKED

Cross-Site Scripting (XSS)

- <script> payload → BLOCKED

- javascript: URI → BLOCKED

- onerror event injection → BLOCKED

- SVG-based XSS → BLOCKED

-

Command Injection

- ; cat /etc/passwd → BLOCKED
- \$(whoami) → BLOCKED
- cmd.exe execution → BLOCKED
- /etc/shadow reference → BLOCKED

Other Attacks

- Path traversal (../../etc/passwd) → BLOCKED
- XXE payload → BLOCKED
- SSTI payload → BLOCKED
- Sensitive data in URL → LOGGED
- Obfuscated payload (double encoding) → BLOCKED

6. Security Header Verification

All required security headers were verified successfully.

- Content-Security-Policy → PASS
- X-Content-Type-Options → PASS
- X-Frame-Options → PASS
- Referrer-Policy → PASS
- Permissions-Policy → PASS
- HSTS → PASS
- Server header removed → PASS
- X-Powered-By removed → PASS - CORS properly restricted → PASS

7. Input Validation Testing

15 validation test cases were executed across different input types.

- Email format validation → PASS
- Password complexity enforcement → PASS
- Name validation rules → PASS

-

- Phone format validation → PASS
- Date and DOB validation → PASS
- UUID format validation → PASS
- MFA code validation → PASS
- Free-text sanitization → PASS
- List input validation → PASS
- Boundary cases and edge inputs → PASS

8. Test Summary

Total Tests Executed: 63

Authentication Tests: 10/10 PASS

Authorization Tests: 8/8 PASS

WAF Tests: 21/21 BLOCKED/LOGGED

Header Tests: 9/9 PASS

Input Validation Tests: 15/15 PASS

Failures: 0 Open

Issues: 0

9. Conclusion

The application successfully resisted all tested attack scenarios. Security mechanisms including WAF, RBAC, validation, and rate limiting performed reliably under all conditions. The system demonstrates strong security readiness and aligns well with industry best practices.